

A continuación, se presenta un documento exhaustivo que puede servir como base de conocimiento para una inteligencia artificial, centrándose en la protección de datos personales y la ciberseguridad en Ecuador, según la información proporcionada en las fuentes.

Base de Conocimiento: Protección de Datos Personales y Ciberseguridad en Ecuador

Esta base de conocimiento abarca los marcos legales y regulatorios, las obligaciones empresariales, el panorama de la ciberseguridad, los actores clave y las recomendaciones para el cumplimiento en Ecuador.

1. Ley Orgánica de Protección de Datos Personales (LOPDP)

La Ley Orgánica de Protección de Datos Personales (LOPDP), aprobada por la Asamblea Nacional de Ecuador en mayo de 2021 y publicada en el Registro Oficial Suplemento No. 459 el 26 de mayo de 2021, es un cuerpo normativo fundamental. Su finalidad es proteger a los ciudadanos ecuatorianos del mal uso y abuso de su información personal, a la vez que exige a empresas y organizaciones el cumplimiento de estándares que garanticen la seguridad de los datos. La ley entró en vigor desde su publicación, con un plazo de dos años para la entrada en funcionamiento del sistema sancionatorio.

1.1. Objeto y Ámbito de Aplicación

- **Objeto:** Garantizar el ejercicio del derecho a la protección de datos personales, incluyendo el acceso y la decisión sobre esta información, así como su protección. Para ello, regula principios, derechos, obligaciones y mecanismos de tutela.
- **Ámbito Material:** Se aplica al tratamiento de datos personales en cualquier tipo de soporte (automatizados o no) y a toda modalidad de uso posterior.
- **Ámbito Territorial:** Se aplica a todas las personas naturales y jurídicas, nacionales y extranjeras, del sector público y privado, que realicen tratamiento de datos personales, independientemente de si sus actividades tienen lugar en territorio ecuatoriano o no.
- **Apoderado Especial:** Los responsables y encargados del tratamiento de datos personales de residentes ecuatorianos que no estén establecidos en Ecuador deben designar a un apoderado especial con residencia en el país, con facultades suficientes para comparecer ante instancias administrativas y judiciales. Esta designación es excepcional cuando el tratamiento de datos es ocasional, no incluye datos de categoría especial a gran escala, y es improbable que entrañe un riesgo significativo para los derechos y libertades de las personas. La Autoridad de Protección de Datos Personales emitirá una guía técnica al respecto.

1.2. Principios Fundamentales La LOPDP se rige por principios, además de otros establecidos en la Constitución y tratados internacionales:

- **Juridicidad:** Tratamiento con estricto apego a la Constitución, leyes y jurisprudencia aplicable.
- **Lealtad:** Debe quedar claro para los titulares que sus datos personales están siendo recogidos, utilizados o tratados, así como las formas en que se hará.
- **Finalidad:** Las finalidades del tratamiento deben ser determinadas, explícitas, legítimas y comunicadas al titular. No se pueden tratar datos para fines distintos a los originales, a menos que haya una causal que lo habilite y sea compatible con la finalidad inicial.
- **Minimización de Datos:** Los datos deben ser pertinentes, adecuados y limitados a lo necesario para los fines del tratamiento.
- **Exactitud:** Los datos deben ser exactos y mantenerse actualizados.
- **Transparencia:** El responsable debe informar al titular sobre el tratamiento de sus datos de manera clara y sencilla.
- **Responsabilidad Proactiva:** El responsable debe demostrar el cumplimiento de la ley y evaluar y revisar continuamente sus mecanismos.
- **Aplicación favorable al titular:** En caso de duda, las disposiciones se interpretarán en el sentido más favorable al titular.
- **Independencia del control:** La Autoridad de Protección de Datos ejercerá un control independiente, imparcial y autónomo.

1.3. Tratamiento Legítimo de Datos Personales El tratamiento de datos es legítimo y lícito si cumple alguna de las siguientes condiciones:

- **Consentimiento del titular:** Debe ser libre, específico, informado e inequívoco para una o varias finalidades específicas. Para menores de edad, el consentimiento se obtiene a través de sus representantes legales; los adolescentes a partir de 15 años pueden dar su consentimiento explícito si se especifican claramente los fines.
- **Obligación legal:** Realizado por el responsable en cumplimiento de una obligación legal.
- **Orden judicial:** Realizado por el responsable por orden judicial.
- **Interés público o ejercicio de poderes públicos:** En cumplimiento de una misión realizada en interés público o en ejercicio de poderes públicos conferidos por ley.
- **Ejecución de medidas precontractuales o contractuales:** Para la ejecución de un contrato a petición del titular o para el cumplimiento de obligaciones contractuales.
- **Intereses vitales:** Necesario para proteger un interés esencial para la vida del titular o de otra persona (ej. epidemias, emergencias humanitarias).
- **Fuentes accesibles al público:** Datos que consten en bases de datos de acceso público, respetando el principio de limitación de la finalidad y la compatibilidad con la finalidad que justificó su publicación.
- **Interés legítimo del responsable o tercero:** Siempre que no prevalezca el interés o derechos fundamentales de los titulares.

1.4. Derechos de los Titulares de Datos Personales La LOPDP garantiza diversos derechos a los titulares, que pueden ser ejercidos a través de canales informáticos o físicos, demostrando la titularidad o representación legal:

- **Derecho a la Información:** Ser informado sobre los fines, base legal, tipos de tratamiento, tiempo de conservación, existencia de la base de datos, origen de los

datos, identidad del responsable/delegado de protección de datos, transferencias (nacionales/internacionales), consecuencias de la entrega/negativa de datos, posibilidad de revocar el consentimiento, y mecanismos para ejercer otros derechos.

- **Derecho de Acceso:** Conocer y obtener gratuitamente del responsable acceso a todos sus datos personales y a la información detallada en el derecho a la información, sin justificación. Debe ser atendido en 15 días.
- **Derecho a la Rectificación y Actualización:** Obtener del responsable la rectificación y actualización de datos inexactos, incompletos o erróneos. Debe ser atendido en 15 días.
- **Derecho a la Eliminación (Cancelación):** Solicitar la eliminación de datos personales si no son necesarios para los fines originales, el consentimiento ha sido revocado, o el tratamiento es ilícito, entre otros. Debe ser atendido en 15 días.
- **Derecho de Oposición:** Oponerse al tratamiento de datos personales, especialmente si tiene fines de mercadotecnia directa. El responsable debe dejar de tratar los datos, salvo motivos legítimos imperiosos. Debe ser atendido en 15 días.
- **Derecho a la Portabilidad:** Recibir sus datos personales en un formato compatible, actualizado, estructurado, común, interoperable y de lectura mecánica, o transmitirlos a otros responsables, si es técnicamente posible.
- **Derecho a la Limitación del Tratamiento:** Solicitar la limitación del tratamiento cuando se impugne la exactitud, el tratamiento sea ilícito y el titular se oponga a la supresión, el responsable ya no necesite los datos pero el titular los necesite para reclamaciones, o el titular se haya opuesto al tratamiento y se esté verificando la prevalencia de los intereses.
- **Derecho a no ser objeto de decisiones automatizadas:** No ser sometido a decisiones basadas única o parcialmente en valoraciones automatizadas (incluida la elaboración de perfiles) que produzcan efectos jurídicos o atenten contra sus derechos, con excepciones para contratos, autorización legal, o consentimiento explícito. Para niños, niñas y adolescentes, no se pueden tratar datos sensibles o de estas categorías a menos que sea con autorización expresa o para un interés público esencial con salvaguardas.
- **Derecho a la Educación Digital:** Acceso y disponibilidad de conocimiento, aprendizaje y formación relacionados con el uso adecuado, seguro y responsable de las TIC, con énfasis en la dignidad humana, derechos fundamentales, privacidad, identidad y reputación en línea, ciudadanía digital y protección de datos personales. Este derecho tiene carácter inclusivo y el sistema educativo debe garantizarlo a estudiantes y docentes.
- **Derecho de Consulta Pública y Gratuita:** Ante el Registro Nacional de Protección de Datos Personales.

1.5. Datos de Categorías Especiales y Crediticios

- **Datos Relativos a la Salud:** Las instituciones del Sistema Nacional de Salud y profesionales pueden recolectar y tratar datos de salud de pacientes con consentimiento, salvo excepciones por interés público esencial o fines de medicina preventiva/laboral. Deben cumplir principios de confidencialidad y secreto profesional, y los datos deben ser anonimizados o seudonimizados siempre que sea posible.

- **Datos Biométricos y Genéticos:** Son datos personales únicos que permiten o confirman la identificación de una persona natural (ej. imágenes faciales, huellas dactilares) o información única sobre la fisiología o salud (heredada o adquirida). Su tratamiento indebido puede dar origen a discriminación.
 - **Datos Crediticios:** Información sobre el comportamiento económico de personas naturales para analizar su capacidad financiera. Su tratamiento es lícito si se obtiene de fuentes públicas o facilitadas por el acreedor, y solo puede usarse para análisis de solvencia. No pueden comunicarse una vez transcurridos cinco años desde que la obligación se hizo exigible. Los titulares tienen derecho a acceder, rectificar o eliminar esta información.
-

2. Obligaciones de Empresas (Responsables y Encargados del Tratamiento)

Las empresas en Ecuador, como responsables o encargados del tratamiento de datos personales, deben cumplir con una serie de obligaciones bajo la LOPDP para asegurar un manejo adecuado y seguro de la información.

2.1. Medidas de Seguridad y Evaluación de Riesgos

- **Medidas Técnicas y Organizativas:** Adoptar medidas necesarias para garantizar la seguridad de los datos personales, protegiéndolos contra pérdida, alteración, tratamiento o acceso no autorizado. Esto incluye el uso de soluciones tecnológicas con múltiples capas de seguridad y funcionalidades que protejan los datos.
- **Evaluación de Riesgos:** Realizar una evaluación de riesgos para identificar vulnerabilidades en los sistemas de información y adoptar medidas de seguridad correspondientes. Esta evaluación de impacto es obligatoria para tratamientos sistemáticos y exhaustivos basados en automatización, tratamiento a gran escala de datos especiales o de condenas/infracciones penales, o la observación sistemática a gran escala de zonas de acceso público.
- **Protección Desde el Diseño y por Defecto (Privacy by Design/Default):** Tener en cuenta desde las primeras fases de diseño de un proyecto los riesgos para los derechos de los titulares, implementando medidas técnicas y organizativas para garantizar el cumplimiento de la ley. Por defecto, solo se deben tratar los datos estrictamente necesarios para cada fin.

2.2. Procedimientos y Documentación

- **Procedimientos Claros:** Desarrollar y documentar procedimientos claros para la recogida, almacenamiento, uso y eliminación de datos personales, asegurándose de que estén alineados con los principios de la LOPDP (minimización, limitación de finalidad, exactitud).
- **Registros de Actividades de Tratamiento:** Los responsables con cien o más trabajadores deben llevar un registro de todas las actividades de tratamiento de datos personales, incluyendo información como fines del tratamiento, categorías de destinatarios y datos personales, uso de perfiles, transferencias internacionales,

bases legitimadoras, plazos de retención y descripción de medidas de seguridad. Este registro debe ser escrito o electrónico y estar disponible para la Autoridad de Protección de Datos Personales. La obligación se extiende a responsables con menos de cien trabajadores si el tratamiento implica riesgo para los derechos, no es ocasional, o incluye categorías especiales de datos. Los encargados también deben mantener un registro si el responsable está obligado.

- **Conservación de Datos:** Los plazos de conservación no deben exceder lo estrictamente necesario para los fines del tratamiento. Una vez cumplidas las finalidades y sin otra obligación legal o interés legítimo, los datos deben ser eliminados, bloqueados o anonimizados.

2.3. Personal y Capacitación

- **Capacitación Regular:** Capacitar regularmente al personal sobre las prácticas correctas de protección de datos y el conocimiento de la ley es fundamental para prevenir infracciones. Esto incluye la inducción sobre ciberseguridad para nuevos empleados.
- **Acuerdos de Confidencialidad:** Suscribir contratos de confidencialidad y manejo adecuado de datos con el personal y encargados del tratamiento.

2.4. Gestión de Incidentes de Seguridad

- **Plan de Respuesta a Incidentes:** Contar con un plan de respuesta a incidentes en caso de una brecha de seguridad.
- **Notificación de Violaciones de Seguridad:** La LOPDP exige que se notifiquen ciertas violaciones de seguridad a la autoridad competente y, en algunos casos, a los afectados, en plazos específicos. La notificación debe ser en lenguaje claro y sencillo.

2.5. Relación con Terceros y Transferencias Internacionales

- **Contratos con Encargados del Tratamiento:** La relación entre el responsable y el encargado debe regirse por un contrato escrito que detalle las instrucciones, objeto, duración, naturaleza, finalidad, categorías de datos, titulares afectados, y obligaciones y responsabilidades del encargado. El encargado debe garantizar medidas técnicas y organizativas adecuadas, equiparables a las del responsable.
- **Transferencia o Comunicación de Datos a Terceros:** Requiere el consentimiento del titular, a menos que los datos hayan sido disociados o cifrados robustamente. La información debe ser exacta, completa y actualizada.
- **Transferencias Internacionales:** Son posibles si se cumplen niveles adecuados de protección o garantías adecuadas. La Autoridad de Protección de Datos Personales determinará los países u organizaciones con niveles adecuados de protección mediante resolución motivada. Si no hay nivel adecuado, se pueden usar instrumentos jurídicamente vinculantes, normas corporativas vinculantes (BCRs), cláusulas tipo, códigos de conducta o mecanismos de certificación que ofrezcan garantías adecuadas. En casos no contemplados, se requiere autorización previa de la Autoridad.

2.6. Auditorías y Revisión del Cumplimiento

- **Revisión Regular:** El entorno legal y tecnológico cambia constantemente, por lo que es crucial revisar regularmente las prácticas de protección de datos y su conformidad con la LOPDP.
- **Auditorías:** Pueden incluir auditorías internas o la contratación de terceros para evaluar el cumplimiento. Una auditoría debe definir el alcance, identificar el marco normativo, asignar un equipo auditor, elaborar un plan, revisar documentación (políticas, contratos, registros de actividades, evaluaciones de impacto), verificar el ejercicio de derechos ARCO, comprobar la legitimidad de datos sensibles/biométricos, evaluar la gestión de riesgos, y analizar accesos/trazabilidad. Los resultados se presentan en un informe con hallazgos, no conformidades y recomendaciones priorizadas. El seguimiento es crucial para la mejora continua.

2.7. Delegado de Protección de Datos (DPO)

- **Rol:** Es una persona natural que asesora, vela y supervisa, de manera independiente, el cumplimiento de las obligaciones legales del responsable y encargado del tratamiento de datos personales.
- **Designación Obligatoria:** La LOPDP establece los casos en que se debe designar un DPO. Los grupos empresariales pueden designar un único DPO si puede ejecutar sus actividades sin conflicto de intereses.
- **Funciones:** Asesorar al responsable, personal y encargado sobre la ley y regulaciones; supervisar el cumplimiento; asesorar en análisis de riesgo y evaluaciones de impacto; cooperar y actuar como punto de contacto con la Autoridad de Protección de Datos Personales.
- **Requisitos:** Estar en goce de derechos políticos, ser mayor de edad, tener título de tercer nivel en Derecho, Sistemas de Información, Comunicación o Tecnologías, y acreditar al menos cinco años de experiencia profesional.
- **Independencia:** El DPO puede ser contratado bajo relación de dependencia o por prestación de servicios, pero debe garantizarse su independencia. No pueden ser DPO quienes formen parte de órganos de administración y control, socios/accionistas del responsable/encargado, o parientes de administradores/directores, ni quienes tengan conflictos de interés. El responsable y encargado no pueden sancionarlo o destituirlo por el correcto desempeño de sus funciones. El DPO debe suscribir un acuerdo de confidencialidad.

3. Autoridad de Protección de Datos Personales (APDP)

La Autoridad de Protección de Datos Personales es el órgano de control y vigilancia encargado de garantizar la protección de datos personales en Ecuador. A fecha de la recopilación de algunos datos (Marzo 2022), la Superintendencia de Protección de Datos (SPD) aún no estaba formalmente establecida como autoridad de control. El Reglamento General a la Ley Orgánica de Protección de Datos Personales fue publicado el 13 de noviembre de 2023.

3.1. Estructura y Atribuciones

- **Autonomía:** Goza de autonomía administrativa, técnica, operativa y financiera.

- **Sede:** Distrito Metropolitano de Quito, a cargo del Superintendente de Protección de Datos Personales.
- **Superintendente:** Designado por terna del Presidente de la República, bajo criterios de especialidad y mérito, sujeto a escrutinio público. Debe ser profesional del Derecho, Sistemas de Información, Comunicación o Tecnologías, con título de cuarto nivel y al menos 10 años de experiencia afín.
- **Atribuciones Principales:**
 - Hacer cumplir las regulaciones de protección de datos personales.
 - Registrar bases de datos personales en el Registro Nacional de Protección de Datos Personales.
 - Dirigir y administrar el Registro Único de Responsables y Encargados Incumplidos.
 - Emitir regulaciones, informes técnicos, y proponer reformas a la ley y su reglamento.
 - Emitir guías de referencia para ayudar a los responsables y encargados en el proceso de adecuación.
 - Conocer y resolver peticiones, quejas, reclamos y recursos.
 - Realizar reportes continuos sobre la realidad internacional en protección de datos.
 - Publicar la lista de países/organizaciones/empresas con niveles adecuados de protección de datos.

3.2. Registros y Mecanismos de Control

- **Registro Nacional de Protección de Datos Personales:** Los responsables deben registrar sus bases de datos o tratamientos de datos personales en un plazo de diez días desde el inicio del tratamiento. Este registro no implica los datos contenidos, sino información sobre la base de datos o el tratamiento.
- **Registro Único de Responsables y Encargados Incumplidos:** Registro público a cargo de la Autoridad de Protección de Datos, donde constarán responsables y encargados que hayan incurrido en infracciones con resolución firme. Tendrá fines sociales, estadísticos, preventivos y de capacitación. El plazo máximo de conservación de datos en este registro es de siete años.
- **Procedimientos de Control:** Se regirán por las reglas del Código Orgánico Administrativo.
- **Mecanismos de Autorregulación:** La Autoridad mantendrá un registro de mecanismos como códigos de conducta y certificaciones.
 - **Certificación:** Determina el grado de cumplimiento de un mecanismo de autorregulación con la LOPDP y su normativa. La Autoridad emitirá los parámetros básicos de evaluación. Las entidades certificadoras deben demostrar independencia, experiencia y procedimientos adecuados.
 - **Códigos de Conducta:** Personas naturales o jurídicas, asociaciones o gremios pueden presentar códigos de conducta para su aprobación, con el fin de cumplir la normativa. Deben describir el objetivo, ámbito de aplicación y mecanismos de supervisión.

3.3. Régimen Sancionatorio

- Las disposiciones relacionadas con las medidas correctivas y el régimen sancionatorio entraron en vigencia dos años después de la publicación de la ley (es decir, en mayo de 2023).
 - En casos de presunta infracción, la Autoridad de Protección de Datos iniciará el procedimiento administrativo sancionatorio. Las medidas correctivas pueden incluir el cese del tratamiento, la eliminación de datos o la imposición de medidas técnicas/organizativas.
 - Si el responsable o encargado es una organización sin domicilio en Ecuador, se notificará a la autoridad de protección de datos de su domicilio principal para que sustancie las acciones de cumplimiento.
-

4. Panorama de la Ciberseguridad en Ecuador

El diagnóstico de capacidades de ciberseguridad en Ecuador (información recopilada hasta marzo de 2022, con algunas actualizaciones hasta agosto de 2022) revela un nivel de madurez generalmente "formativo a establecido" en sus cinco dimensiones.

4.1. Dimensiones de Capacidad de Ciberseguridad Evaluadas El modelo de madurez de capacidad de ciberseguridad (CMM) de la Universidad de Oxford evalúa cinco dimensiones:

1. **Política y Estrategia de Ciberseguridad:** Evalúa la capacidad para desarrollar e implementar una estrategia nacional, y mejorar la ciberresiliencia a través de la respuesta a incidentes, gestión de crisis, ciberdefensa y protección de infraestructuras críticas. Nivel de madurez: Formativo a Establecido.
2. **Cultura Cibernética y Sociedad:** Evalúa la comprensión de riesgos cibernéticos, confianza en servicios en línea, comprensión de la protección de datos personales, mecanismos de denuncia y el papel de los medios de comunicación y redes sociales. Nivel de madurez: Formativo a Establecido.
3. **Desarrollo de Conocimiento y Capacidades en Ciberseguridad:** Evalúa la disponibilidad, calidad y aceptación de programas de concientización, educación formal y capacitación profesional en ciberseguridad. Nivel de madurez: Formativo a Establecido.
4. **Marcos Legales y Regulatorios:** Examina la capacidad del Gobierno para formular y promulgar un marco jurídico integral sobre ciberseguridad, delitos informáticos, y la capacidad de las agencias para hacer cumplir las leyes. Nivel de madurez: Formativo a Establecido.
5. **Estándares y Tecnologías:** Evalúa el uso efectivo y generalizado de tecnologías de ciberseguridad, implementación de estándares, controles, y el desarrollo de productos para reducir riesgos y mejorar la resiliencia. Nivel de madurez: Formativo a Establecido.

4.2. Principales Desafíos en Ciberseguridad

- **Marco Legal y Regulatorio:** Ecuador carecía de un marco legal y regulatorio integral de ciberseguridad que aborde requisitos de seguridad, notificación de incidentes, divulgación de vulnerabilidades y otros aspectos a nivel nacional. Existen disposiciones sectoriales, pero no un marco unificado. Aunque se aprobó la LOPDP,

la Superintendencia de Protección de Datos (SPD) no estaba formalmente establecida para velar por su cumplimiento.

- **Infraestructuras Críticas (IC):** Ecuador no ha identificado formalmente los sectores, subsectores y activos de las infraestructuras críticas a nivel nacional, y las evaluaciones existentes no incluyen al sector privado.
- **Capacidad de Respuesta a Incidentes (CERT):** Ecuador no cuenta con un CERT nacional con capacidad y recursos adecuados para gestionar el ciclo de respuesta a incidentes cibernéticos a nivel nacional. El EcuCERT, aunque impulsado a asumir este rol, tiene limitaciones significativas en mandato legal, recursos financieros y tecnológicos, personal capacitado, y horario de funcionamiento (8x5 en lugar de 24x7).
- **Concientización y Cultura Cibernética:** El nivel de conciencia y conocimiento sobre ciberseguridad en Ecuador es creciente, pero aún no alcanza un nivel adecuado en general, especialmente en el sector público y las PYMES. No existe un programa articulado de concientización a nivel nacional.
- **Educación y Capacitación:** Existe una escasez de profesores especializados en ciberseguridad y pocas iniciativas públicas para incentivar esta carrera. Los planes de estudio universitarios a menudo tienen una cobertura insuficiente de temas de ciberseguridad.
- **Capacidades Forenses y Judiciales:** La Unidad de Delitos Cibernéticos de la Policía Nacional tiene recursos limitados y necesita mejorar herramientas tecnológicas. La Fiscalía General no tenía una unidad especializada en delitos informáticos (aunque se creó una en junio de 2022), y la mayoría de los jueces carecen de conocimiento profundo sobre delitos informáticos y evidencia digital.
- **Inversión:** Hay baja inversión en prevención y en ciberseguridad a nivel general, con presupuestos limitados para áreas clave como el EcuCERT y la investigación.

4.3. Esfuerzos y Avances Gubernamentales

- **Política Nacional de Ciberseguridad (PNC) y Estrategia Nacional de Ciberseguridad (ENC):** Ecuador adoptó su primera PNC en 2021. La Estrategia Nacional de Ciberseguridad 2022-2025 (ENC) fue aprobada en agosto de 2022, estableciendo seis pilares estratégicos: gobernanza, resiliencia cibernética, prevención y combate a la ciberdelincuencia, ciberdefensa, habilidades y cooperación internacional.
- **Alfabetización Digital y Servicios en Línea:** El MINTEL ha impulsado programas de alfabetización digital ("Puntos de Encuentro", "habilidades digitales", "Internet para todos") y ha digitalizado el 60% de los trámites gubernamentales, con el objetivo de alcanzar el 100%.
- **Adhesión a Convenios Internacionales:** Ecuador está trabajando en la adhesión al Convenio de Budapest sobre cibercriminalidad. También participa activamente en foros y grupos internacionales de ciberseguridad.
- **Fortalecimiento Institucional:**
 - **Fiscalía:** Se creó la "Unidad Nacional Especializada en Investigación de Ciberdelito" en junio de 2022.
 - **EcuCERT:** Aunque con limitaciones, ha sabido posicionarse internacionalmente y forma parte de la comunidad FIRST. Ha establecido la

Red Nacional de Confianza (RNC) para el intercambio de información con CERTs públicos y privados.

- **Ministerio de Defensa Nacional (MDN) y COCIBER:** El MDN es el ente rector de la ciberdefensa. Adoptó la Estrategia de Ciberdefensa en 2021. El COCIBER realiza evaluaciones de riesgos cibernéticos y cuenta con un CERT militar reconocido por la OEA.

5. Recomendaciones Clave para el Fortalecimiento (Síntesis de las Fuentes)

Para mejorar la postura de ciberseguridad y el cumplimiento de la LOPDP en Ecuador, se desprenden las siguientes recomendaciones:

5.1. Fortalecimiento del Marco Legal y Regulatorio

- **Evaluación Continua:** Evaluar periódicamente las disposiciones legales sobre delitos informáticos (COIP) y otros marcos regulatorios para identificar vacíos y brechas, con colaboración de socios internacionales [R4.1, 376].
- **Marco Integral de Ciberseguridad:** Incorporar leyes y reglamentos que aborden la protección de infraestructuras críticas, uso obligatorio de estándares de seguridad, notificación de incidentes y brechas, divulgación responsable de vulnerabilidades e intercambio de información [R4.5, 378].
- **Armonización:** Armonizar continuamente el marco legal y regulatorio de ciberseguridad con políticas públicas, tratados internacionales (ej. Convenio de Budapest) y buenas prácticas [R4.2, 377].
- **Transparencia Legislativa:** Asegurarse de que las leyes y reglamentos sobre ciberseguridad sean ampliamente discutidos y consultados con todos los actores del ecosistema [R4.3, 377].
- **Protección de Derechos Humanos:** Evaluar si las disposiciones legales cumplen con los estándares internacionales de protección de derechos humanos en entornos digitales [R4.6, 378].
- **Establecimiento de la APDP:** Acelerar el establecimiento formal de la Superintendencia de Protección de Datos (SDP) con recursos suficientes, y que esta lidere campañas de concientización masivas sobre la LOPDP [R4.9, R4.10, 380].

5.2. Mejora de la Cultura y Concientización Cibernética

- **Programa Nacional de Concientización:** Establecer un programa nacional coordinado de concientización sobre ciberseguridad, dirigido a la población general (especialmente grupos vulnerables: niños, adultos mayores, PYMES) y ejecutivos, con un plan de implementación detallado y contenido relevante [R2.4, R3.1, R3.2, 290, 322].
- **Centralización y Recursos:** Designar una entidad coordinadora con mandato y recursos para llevar a cabo estas campañas, y centralizar la administración de capacitaciones [R2.2, R3.3, 289, 324].

- **Educación Temprana:** Promover la inclusión de contenidos de ciberseguridad en la malla curricular de educación primaria y secundaria [R2.11, R3.14, 293, 330].
- **Colaboración Multisectorial:** Fomentar alianzas público-privadas con cámaras de comercio, proveedores de Internet, sociedad civil y academia para maximizar el alcance y el impacto de las campañas [R2.3, R2.5, R2.12, R3.6, 290, 291, 294, 325].
- **Medición de Confianza:** Evaluar periódicamente el nivel de conocimiento y confianza de los ciudadanos en el uso de Internet y servicios digitales [R2.6, 291].
- **Combate a la Desinformación:** Desarrollar políticas públicas y/o marcos legales para combatir la desinformación, fortaleciendo la coordinación multisectorial y la cooperación internacional [R2.7, 292].

5.3. Fortalecimiento de Capacidades y Conocimientos

- **Formación de Formadores:** Crear programas de educación para profesores y académicos en ciberseguridad [R3.7, 326].
- **Incentivos para Profesionales:** Crear incentivos para que profesionales calificados se interesen en la docencia de ciberseguridad [R3.8, 326].
- **Oferta Académica:** Integrar más contenidos y cursos de ciberseguridad en carreras tecnológicas y no tecnológicas, promoviendo el carácter multidisciplinario. Promover la creación de más cursos y carreras especializadas [R3.10, R3.11, R3.13, 328, 329].
- **Evaluación de Oferta y Demanda:** Desarrollar métricas para evaluar periódicamente la oferta y demanda académica en ciberseguridad [R3.12, 329].
- **Inversión en Educación e Investigación:** Asignar recursos financieros adicionales para la educación, investigación y laboratorios en ciberseguridad, promoviendo alianzas público-privadas para programas de investigación e innovación sostenibles [R3.15, R3.16, R3.33, R3.34, 330, 331, 339].
- **Programa Nacional de Capacitación Profesional:** Crear un programa nacional de capacitación para profesionales con beneficios, incentivos y subsidios, y un portal web para la coordinación e intercambio de información [R3.24, R3.25, R3.26, 335, 336].
- **Retención de Talento:** Desarrollar políticas e incentivos para retener a profesionales calificados en ciberseguridad en el país y en el sector público [R3.20, R3.29, 333, 338].

5.4. Mejora de la Respuesta a Incidentes y Gestión de Crisis

- **Fortalecer EcuCERT:** Evaluar y fortalecer el mandato legal, capital humano, recursos tecnológicos, procedimientos operativos y desempeño del EcuCERT para que opere como el centro nacional de respuesta a incidentes de Ecuador (CERT nacional) [R1.3, R1.4, R1.5, R1.6, R1.11, R1.12, 255, 256, 257, 258, 259].
- **Registro Centralizado:** Asegurarse que el EcuCERT registre todos los incidentes cibernéticos a nivel nacional y tenga procedimientos de escalamiento [R1.4, 256].
- **Marco de Notificación Obligatoria:** Elaborar e implementar un marco nacional que obligue a todas las instituciones (públicas y privadas, incluyendo IC) a reportar incidentes cibernéticos de forma oportuna al CERT nacional [R1.7, 257].
- **Intercambio de Información:** Elaborar e implementar un marco y/o plataforma nacional para el intercambio de información sobre incidentes, vulnerabilidades y

medidas preventivas, con protocolos formales de confidencialidad y ampliación de la comunidad objetivo [R1.8, 257].

- **Planes de Gestión de Crisis:** Considerar la elaboración e implementación de un plan nacional de gestión de crisis que integre la ciberseguridad, designando un ente responsable con funciones claras y recursos [R1.12, 259].
- **Simulacros Nacionales:** Implementar un programa nacional de simulacros de ciberseguridad (cyberdrills) con la participación de todos los actores relevantes del ecosistema [R1.13, 259].

5.5. Protección de Infraestructuras Críticas (IC)

- **Identificación y Regulación:** Formalizar y difundir la lista oficial de sectores de infraestructuras críticas digitales y servicios esenciales. Desarrollar e implementar un marco regulatorio que obligue a operadores y proveedores a cumplir con estándares técnicos y legales específicos (seguridad, reporte, evaluación de riesgos, cadena de suministro, divulgación responsable) [R1.17, R1.18, 260, 261].
- **Gobernanza de IC:** Establecer un modelo de gobernanza que determine las agencias gubernamentales y reguladores sectoriales responsables de monitorear y hacer cumplir el marco regulatorio [R1.19, 261].
- **Buenas Prácticas Voluntarias:** Aunque no exista un marco regulatorio completo, los proveedores y operadores de servicios esenciales deberían considerar la implementación de estándares internacionales, auditorías periódicas, gestión de dependencias transfronterizas y capacitaciones [R1.20, 262].

5.6. Estándares y Tecnologías

- **Esquema Nacional de Seguridad de la Información (ENSI):** Desarrollar e implementar un ENSI basado en estándares y buenas prácticas internacionales, aplicable a los sectores público y privado (voluntario u obligatorio) [R5.1, R5.2, 409].
- **Cumplimiento del EGSi v2.0:** Asegurarse de que MINTEL tenga los recursos para auditar y supervisar el cumplimiento del EGSi v2.0 por parte de las instituciones públicas obligadas, y que todas logren el 100% de cumplimiento [R5.6, R5.7, 411].
- **Controles de Seguridad:** Implementar controles técnicos actualizados (parches, copias de seguridad) y físicos para prevenir accesos no autorizados [R5.10, 412]. Promover el uso generalizado de controles criptográficos robustos para datos en reposo y en tránsito (SSL/TLS) [R5.14, R5.15, 413].
- **Calidad de Software:** Desarrollar catálogos de plataformas y aplicaciones de software seguras que cumplan con estándares y buenas prácticas internacionales [R5.16, R5.19, 414, 415].
- **Mercado de Ciberseguridad:** Incentivar el desarrollo de un mercado de ciberseguridad local robusto, incluyendo servicios de consultoría y ciberseguros accesibles para PYMES.

Las empresas especializadas, como KVA, Procesos IQ, Corporación CISMO, Nube Digital, Binaria IT Services, Refundation, GayaIT, RKLATAM, Byte atómico, Bi Solutions, Laydataconsulting, y Spingarn, ofrecen servicios de consultoría integral, implementación, auditoría, asesoría DPO, seguridad de la información, y desarrollo de soluciones

tecnológicas para ayudar a las empresas a cumplir con la LOPDP y fortalecer su ciberseguridad. Además, existen soluciones de software como myLOPDP que automatizan la gestión de la protección de datos personales para consultores y empresas.